

摩诃草团伙利用公用平台分发C&C配置攻击活动揭露

2019-08-26 By 红雨滴团队 | 事件追踪

概述

近期，奇安信威胁情报中心红雨滴团队利用公开情报发现一个摩诃草团伙的XLSM诱饵文档样本，经过分析发现其载荷主要通过 Github 和 Feed43获取加密的 C&C配置。通过关联分析我们找到了更多被摩诃草利用的 Github 地址，最早可以追溯到2018年7月，并且截至报告完成时，相关账号依然在使用。

本文主要对Github上配置文件的解密算法分析和通过解密的数据总结出攻击者的一些活动特征。

样本分析

相关投递的Dropper是一个 XLSM文件，打包时间是2019年8月8号，上传到VT的时间是8月13号。该文档是利用CVE-2017-11882漏洞释放MSBuild.exe到%appdata%目录下，通过写Run启动项实现持久化；通过对攻击者掌握的Github和Feed43账号发布的内容进行读取，解密出C&C，并通过http/https隧道通信。

Dropper样本分析

该样本被上传到VT的时间为2019-08-13 05:05:15，详细信息如下：

MD5	0D38ADC0B048BAB3BD91861D42CD39DF
文件名	India makes Kashmir Dangerous Place in the World.xlsm
时间	2019-08-13 05:05:15

打开图标后是一个模糊的图片，图片提示点击启用宏的话，会出现清晰的内容，标题翻译后的内容为：“印度使克什米尔变成世界上最危险的地方”。



图2.1 打开xlsm后的内容（点击启用宏现实清晰的图片和文字）

其实是清晰的图片上面盖着一个模糊的图片，启用宏的话，会把上面的图片删掉，就会显示下面清晰的图片和文字：

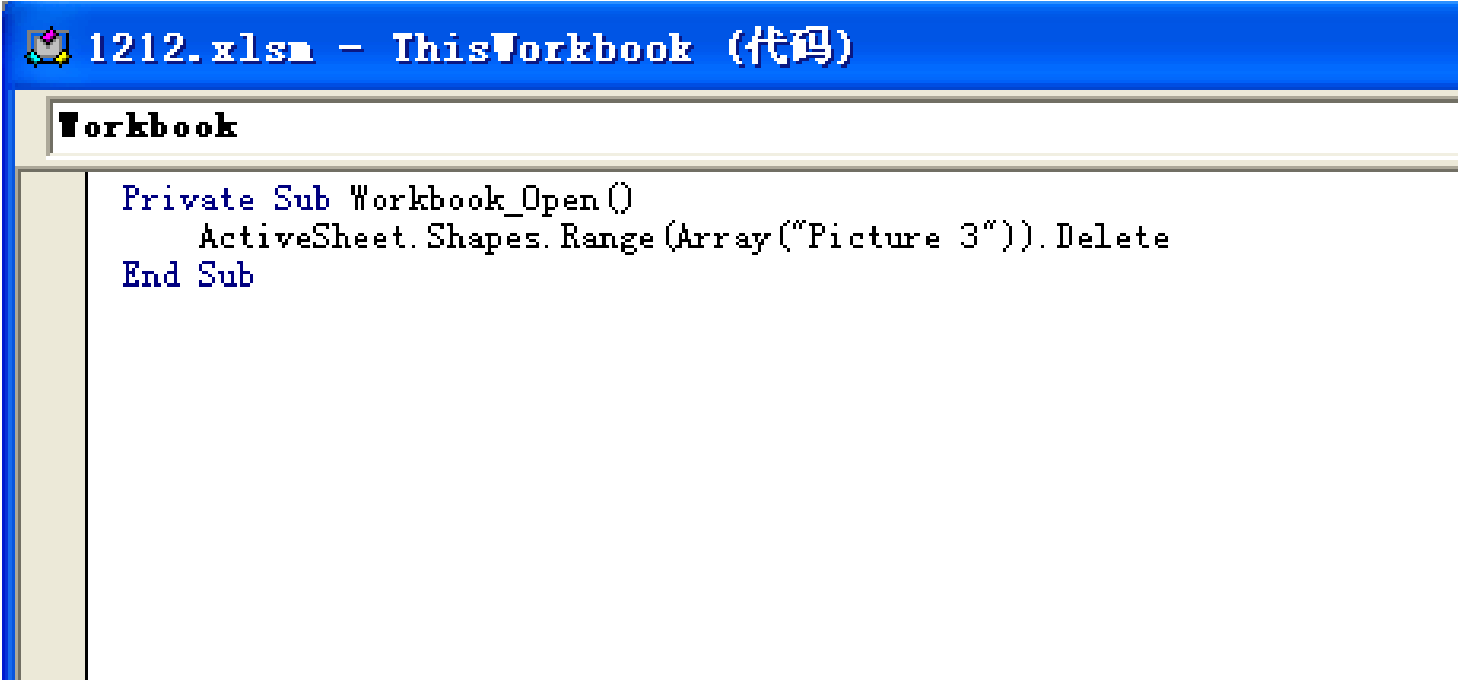


图2.2 宏的内容

通过解包，解出一个ole对象，攻击者似乎不小心把bak的文件也一块打包进去了：

名称	修改日期	类型	大小
oleObject1.bin	2019/8/8 19:10	BIN 文件	197 KB
oleObject1.bin.bak	2019/8/8 19:10	BAK 文件	197 KB

图2.3 攻击者打包进去的ole对象

通过对ole对象中提取的shellcode分析，具体功能如下：

- 从shellcode入口偏移0x558位置修正PE头（前2个字节加上MZ）
- 把修正后的数据写到"%appdata%\MSBuild.exe"文件
- 写注册表run启动（键值：lollipop），指向"%appdata%\MSBuild.exe"

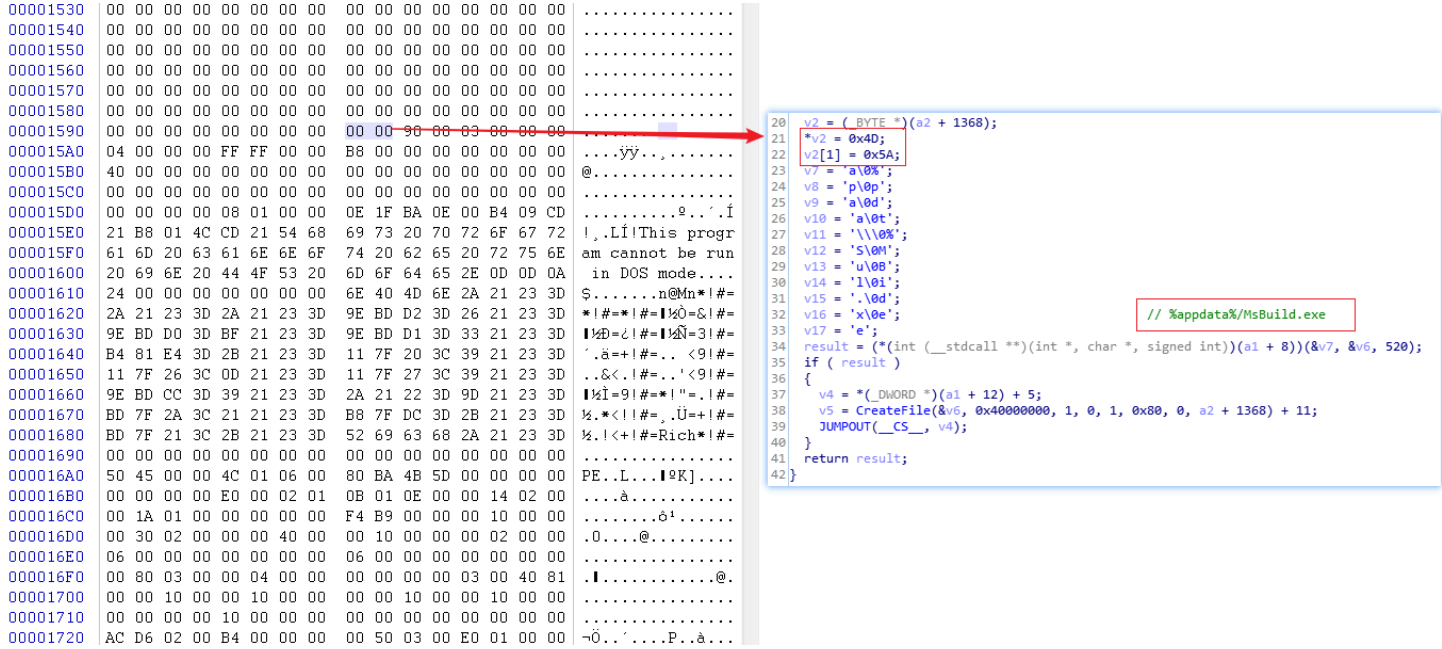


图2.4 shellcode修正PE头

MSBuild.exe分析

MSBuild.exe被释放到%appdata%目录下，编译时间为2019年8月8日；编译时间和本文后面描述的github上的xml创建时间吻合；详细信息如下：

文件名	MSBuild.exe
MD5	0f4f6913c3aa57b1fc5c807e0bc060fc
编译时间	2019-08-08 14:00:32

该样本的主要功能是通过攻击者的Github空间和Feed43空间获取C2配置信息，解密后连接C2实现通信。

该恶意代码执行起来后，会休眠一段时间，休眠是通过执行80000次函数来实现的，这样做是为了躲避沙箱的检测：

```
1 int sub_13E7130()
2 {
3     signed int v0; // esi
4     signed int v1; // ebx
5     int i; // ecx
6     int result; // eax
7
8     v0 = 3;
9     v1 = 2;
10    do
11    {
12        for ( i = 2; i <= v0 - 1; ++i )
13        {
14            result = v0 / i;
15            if ( !(v0 % i) )
16                break;
17        }
18        if ( i == v0 )
19        {
20            result = fun_Print("%d\n", v0);
21            ++v1;
22        }
23        ++v0;
24    }
25    while ( v1 <= 80000 );
26    return result;
27 }
```

图3.1 循环执行函数达到休眠的目的

然后通过连接“<https://en.wikipedia.org>”判断网络联通性；再通过2个配置地址来获取C2的配置文件的信息（2个更保险），2个配置地址的加密算法为单字节加1，通过解密获取到C2的配置文件的地址：

```
35  memset(&String, 0, 0x3C0u);
36  lstrcpyA(&String1, "iuuqt;00opef3/gffe54/dpn01167345289626242/ynm");
37  lstrcpyA(&v16, "iuuqt;00sbx/hjuivcvtfstdpoufou/dpn0qfufstponjlf0uftu0nbtufs0ynm/ynm");
38  v2 = 0;
39  *szAgent = xmmword_12CCA10;
40  v28 = 'gbT6';
41  v23 = xmmword_12CC900;
42  v29 = '0jsb';
43  v24 = xmmword_12CC980;
44  v30 = 792212534;
45  v25 = xmmword_12CC8F0;
46  v31 = 50;
47  v26 = xmmword_12CC980;
48  v27 = xmmword_12CC890;
49  do
50  {
51      *&szAgent[v2] = _mm_sub_epi8(*&szAgent[v2], xmmword_12CC740);
52      *(&v23 + v2) = _mm_sub_epi8(*(&v23 + v2), xmmword_12CC740);
53      v2 += 32;
54  }
55  while ( v2 < 0x60 );
56  for ( ; v2 < 0x6D; ++v2 )
57      --szAgent[v2];
58  v3 = &String;
59  v10 = 12;
```

图3.2 解密2个配置地址

配置源	解密后的字符串
Feed43配置地址	https://node2.feed43.com/0056234178515131.xml
Github配置地址	https://raw.githubusercontent.com/petersonmike/test/master/xml.xml

攻击者使用的这个Github账号的创建时间为2019年8月7号和样本的编译时间吻合：

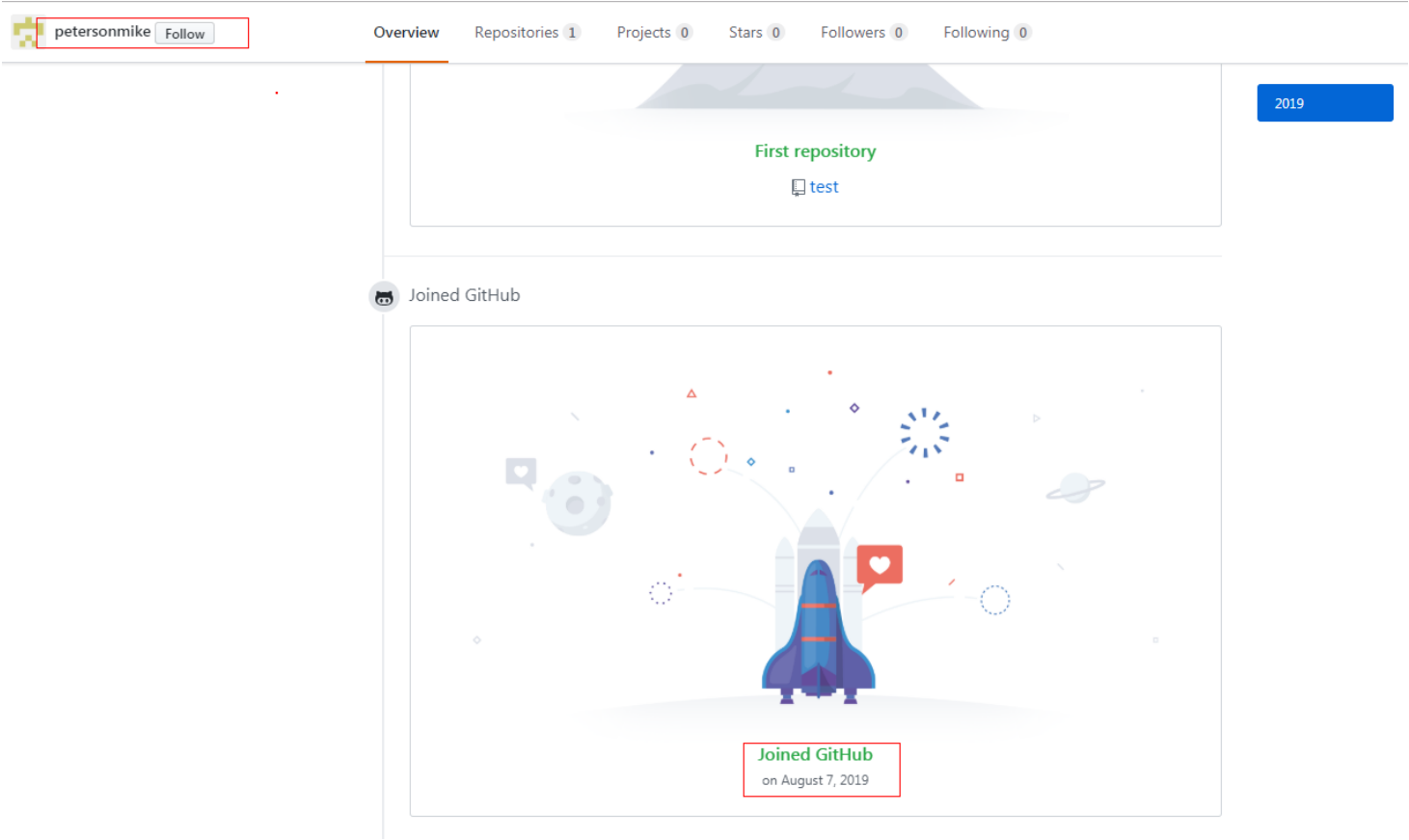


图3.3 攻击者的github主页

攻击者使用的Github的配置信息是从一个很常见的xml配置文件中插入了一个“description”键，该键里存放的是攻击者加密后的C2：



图3.4 Github配置文件内容

按照上图的格式，取出来两个中括号中间的base64编码的数据，然后解密，解密的步骤为先base64解码，然后_ROL1__((v11 + 16 * v9) ^ 0x23, 3)，然后再base64解密，最后逐8字节blowfish解密（老版本的省去blowfish解密这一步）；密钥（16进制）：

F0 E1 D2 C3 B4 A5 96 87 78 69 5A 4B 3C 2D 1E 0F 00 11 22 33 44 55 66 77

解密出C2地址为：139.28.38.236，采用http或者https隧道的形式通信：

```
44 v6[v5] = 0;
45 v7 = fun_Base64DecodeAndXorDecode(v6); // 先base64解码 再自定义解密
46 v8 = v7;
47 v9 = strlenA(v7);
48 v10 = LocalAlloc(0x40u, v9);
49 v20 = v10;
50 fun_base64Decode(v10, v8); // 再Base64解码
51 v25 = 0xC3D2E1F0; // 密钥
52 v26 = 0x8796A5B4;
53 v27 = 0x4B5A6978;
54 v28 = 0xF1E2D3C;
55 v29 = 0x33221100;
56 v30 = 0x77665544;
57 memset(First, 0, 160u);
58 fun_InitBlowFish(&v25, &v21);
59 v11 = strlen(v10);
60 if ( v11 % 8 )
61     v11 = 8 * (v11 / 8) + 8;
62 if ( v11 > 0 )
63 {
64     v12 = v10;
65     v13 = (First - v10);
66     v14 = ((v11 - 1) >> 3) + 1;
67     do
68     {
69         sub_12A6B40(&v12[v13], v12, &v21); // 再逐8字节blowfish解密
70         v12 += 8;
71         --v14;
72     }
73     while ( v14 );
```

图3.5 C2的解密算法

然后会收集一些中招机器的信息，填充到以下字段中，然后通过aes加密后做base64编码发送出去：

字段名	内容
uuid	GetCurrentHwProfile获取的机器码
un	系统的一些信息
cn	电脑名
on	操作系统版本
lan	Ip列表
nop	空
ver	远控版本，这里是1.0

然后进入while循环，会根据http返回的数据去判断要执行的内容；URI和功能如下：

URI	功能
/e3e7e71a0b28b5e96cc492e636722f73/4sVKAOVu3D/ABDYot0NxyG.php	上线、消息队列
/e3e7e71a0b28b5e96cc492e636722f73/4sVKAOVu3D/UYEfGpXAOE.php	上传数据

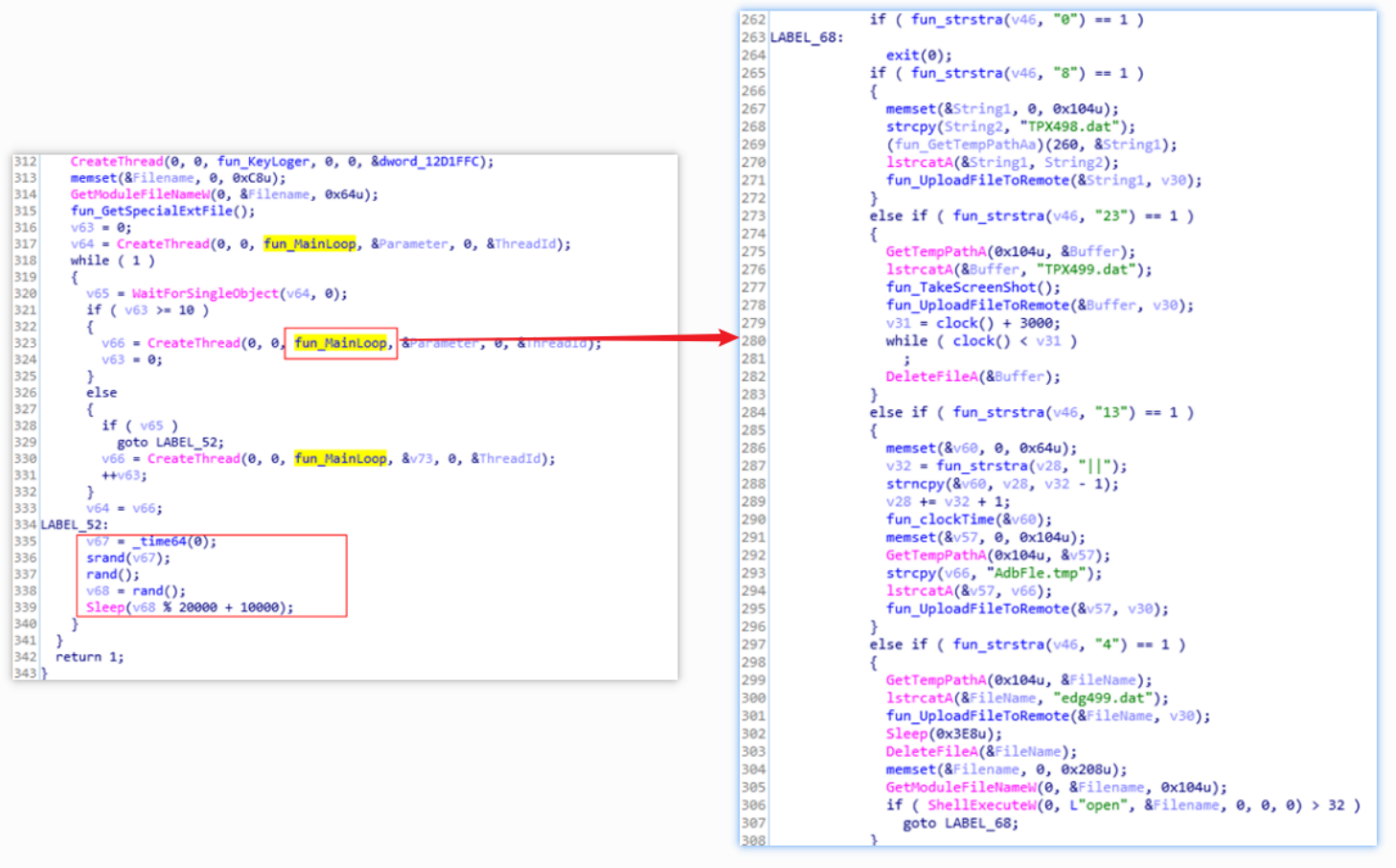


图3.6 循环创建线程并接收消息

下表为收到的token和服务端要执行的功能的对照表：

Token	功能
0	退出
8	上传键盘记录的文件
23	上传截屏的文件
13	上传收集的特定后缀的文件列表
5	上传本地文件到服务器
33	从一个url中提取exe链接并下载执行

攻击者通过下发指令把一些执行命令后的缓存文件上传到C&C服务器上；下表为缓存的文件和记录的内容的对照表：

文件名	记录的内容
9PT568.dat	uuid
TPX498.dat	键盘记录的文件
TPX499.dat	截屏文件
AdbFle.tmp	攻击者指定的待取的受害者文件
edg499.dat	特定后缀的文件列表： (".txt",".doc",".xls",".xlsx",".docx",".xls",".ppt",".pptx",".pdf")

该木马会收集一些特定后缀的文件列表，存放到本地文件中，并上传到C2服务器：

```
20 v13 = this;
21 wsprintfw(&FileName, L"%s\\*.\"", this);
22 hFindFile = FindFirstFileW(&FileName, &FindFileData);
23 if ( hFindFile == (HANDLE)-1 )
24     return 0;
25 do
26 {
27     if ( lstrcmpw(FindFileData.cFileName, L".") && lstrcmpw(FindFileData.cFileName, L"..") )
28     {
29         wsprintfw(&FileName, L"%s\\%", v13, FindFileData.cFileName);
30         if ( FindFileData.dwFileAttributes & 0x10 )
31         {
32             sub_12A8F50(&FileName);
33         }
34         else
35         {
36             v2 = lstrlenW(FindFileData.cFileName);
37             if ( !lstrcmpw((LPCWSTR)&FindFileData.dwReserved0 + v2, L".txt") )
38                 goto LABEL_21;
39             v3 = lstrlenW(FindFileData.cFileName);
40             if ( !lstrcmpw((LPCWSTR)&FindFileData.dwReserved0 + v3, L".doc")
41                 || (v4 = lstrlenW(FindFileData.cFileName), !lstrcmpw((LPCWSTR)&FindFileData.dwReserved0 + v4, L".xls"))
42                 || (v5 = lstrlenW(FindFileData.cFileName), !lstrcmpw((LPCWSTR)&FindFileData.dwReserved0 + v5, L".xlsx"))
43                 || (v6 = lstrlenW(FindFileData.cFileName), !lstrcmpw((LPCWSTR)&FindFileData.nFileSizeLow + v6 + 1, L".docx"))
44                 || (v7 = lstrlenW(FindFileData.cFileName), !lstrcmpw((LPCWSTR)&FindFileData.dwReserved0 + v7, L".xls"))
45                 || (v8 = lstrlenW(FindFileData.cFileName), !lstrcmpw((LPCWSTR)&FindFileData.dwReserved0 + v8, L".ppt"))
46                 || (v9 = lstrlenW(FindFileData.cFileName), !lstrcmpw((LPCWSTR)&FindFileData.dwReserved0 + v9, L".pptx"))
47                 || (v10 = lstrlenW(FindFileData.cFileName), !lstrcmpw((LPCWSTR)&FindFileData.dwReserved0 + v10, L".pdf")) )
48             {
49 LABEL_21:
50                 fun_Print("%s\n", FindFileData.cFileName);
51                 wsprintfw(&String, L" \n%s \r\n", &FileName);
52                 v11 = lstrlenW(&String);
53                 WriteFile(hFile, &String, 2 * v11, &NumberOfBytesWritten, 0);
54             }
55         }
56     }
57 }
58 while ( FindNextFileW(hFindFile, &FindFileData) );
59 FindClose(hFindFile);
60 return 1;
61 }
```

图3.7 收集特定文件后最的文件列表

数据分析

通过关联分析，我们发现该组织托管在 Github 上的总共44个配置文件，提取并通过解密算法解密出所有的C2后，对数据进行分析，从创建时间来看，攻击者最早至少从2018年7月份开始使用，最早创建的账号为2018年7月3日，并且一直延续到2019年8月（文档完成时），从每月创建次数来看，2018年7月的创建次数远超于后续，并且2018年7月-9月的创建数高于后续，我们结合数据分布给出如下合理推测：

- 攻击组织可能在2018年7月-9月组织了一次集中性的攻击活动；
- 攻击组织可能采用需要时才创建的方式，当样本更换或相关更新 Github 链接被封堵后才进行新账户的创建。

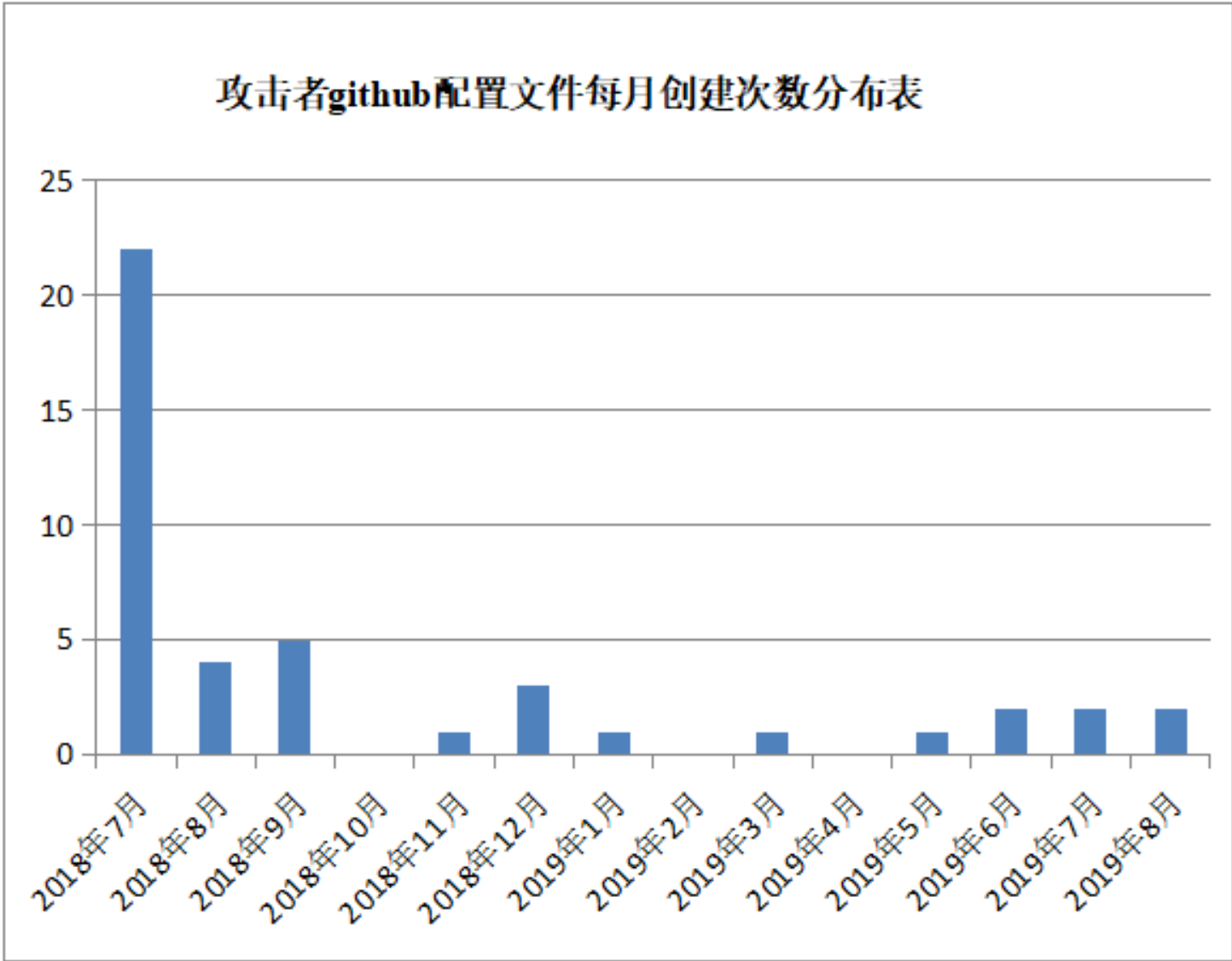


图4.1 攻击者活跃月份分布图

提取所有的攻击者注册的Github用户名如下，我们可以发现其创建的 Github 用户名主要以人的姓氏名称拼接和变化而成，结合其命名变换的特点，可能由多个攻击者分别完成，且其中多个ID在社交媒体可以搜索到，且大多位于印度和巴基斯坦：

malikzafar786,Zunaid-zunaid1,a1amir1,Alaeck,aleks0rg0v,alexboycott,alfreednobeli,chrisyoks,dawood,ehsaankhan,fakheragainfkh,fangflee,habrew,hazkabeeb,husngilgit,imranikhan17,imrankhan713,jahilzubaine,johnhenery12,lctst,noorfirdousi,noorhasima,petersonmike,raqsebalooch,rehmanlaskkr,rizvirehman,shaikmalik22,str1ngstr,Vldir,y4seenkh

an,yamichaeldavid,yusufk1,z00min

根据Github的目录名喜欢用test等字样的目录名，其中还包含了 Android、Mobile 等关键词，或许用于 Android 手机的攻击样本中。

testy,test,amnigomestro,android,blch,cartoon,fashion,harrypotter,haz,helbrat,huric,husnahazrt,introduction,Joncorbat,kjhlkjhl,likingd,mdfs,metest,mobileapp,mobilegame,mypage,playboy,project11,readme,rh0m,s0rg0v,sapt,stz,testhaz,testing,testlct,testme,testmetest,testo,testro,testro1,tests,travel,xml

使用的C2的IP主要分布在乌克兰，中国发现2个IP地址：

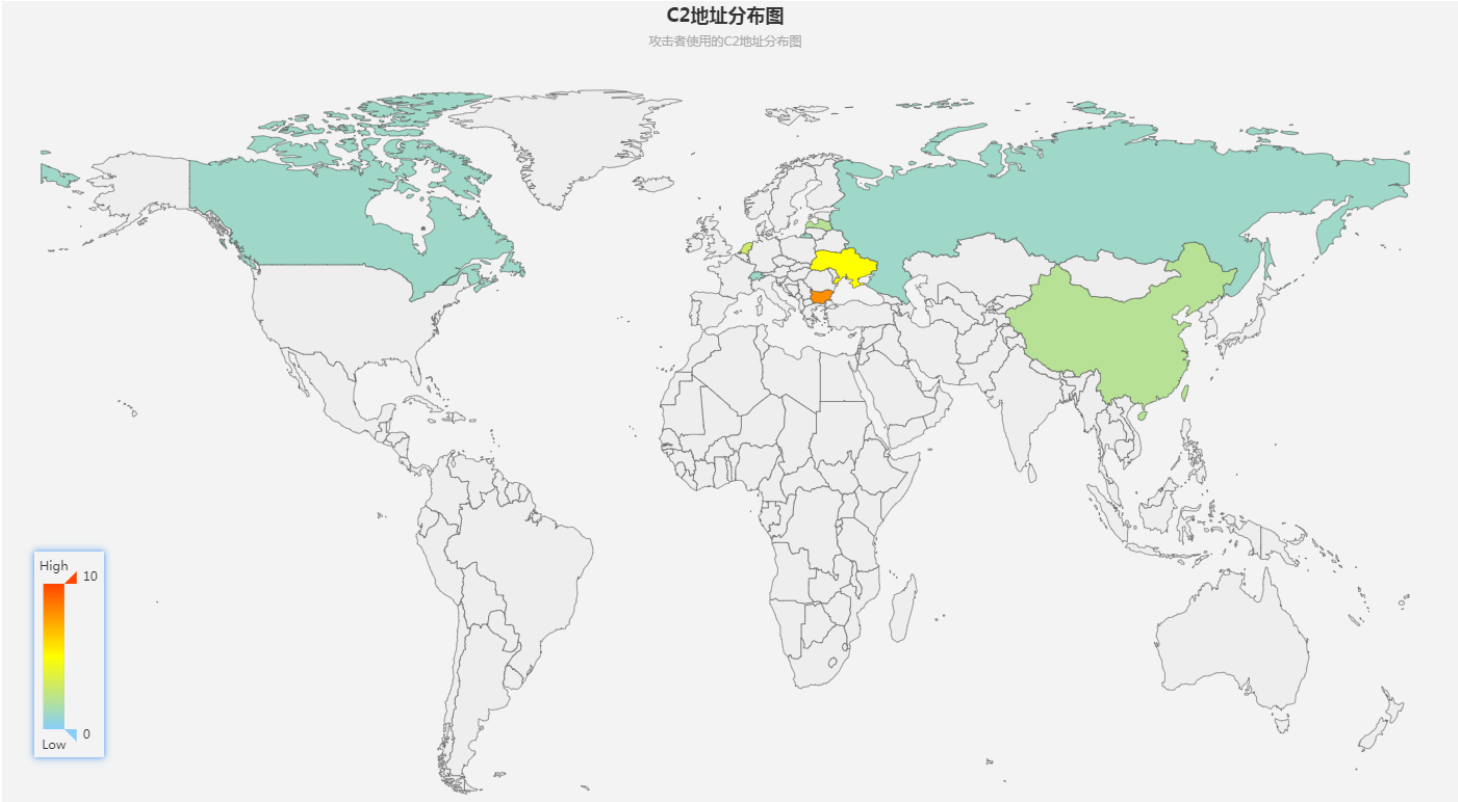


图4.2 C2地址分布图

根据对Github中xml的创建时间进行统计，得下表（横轴是UTC+0的时间，纵轴是出现的次数）。

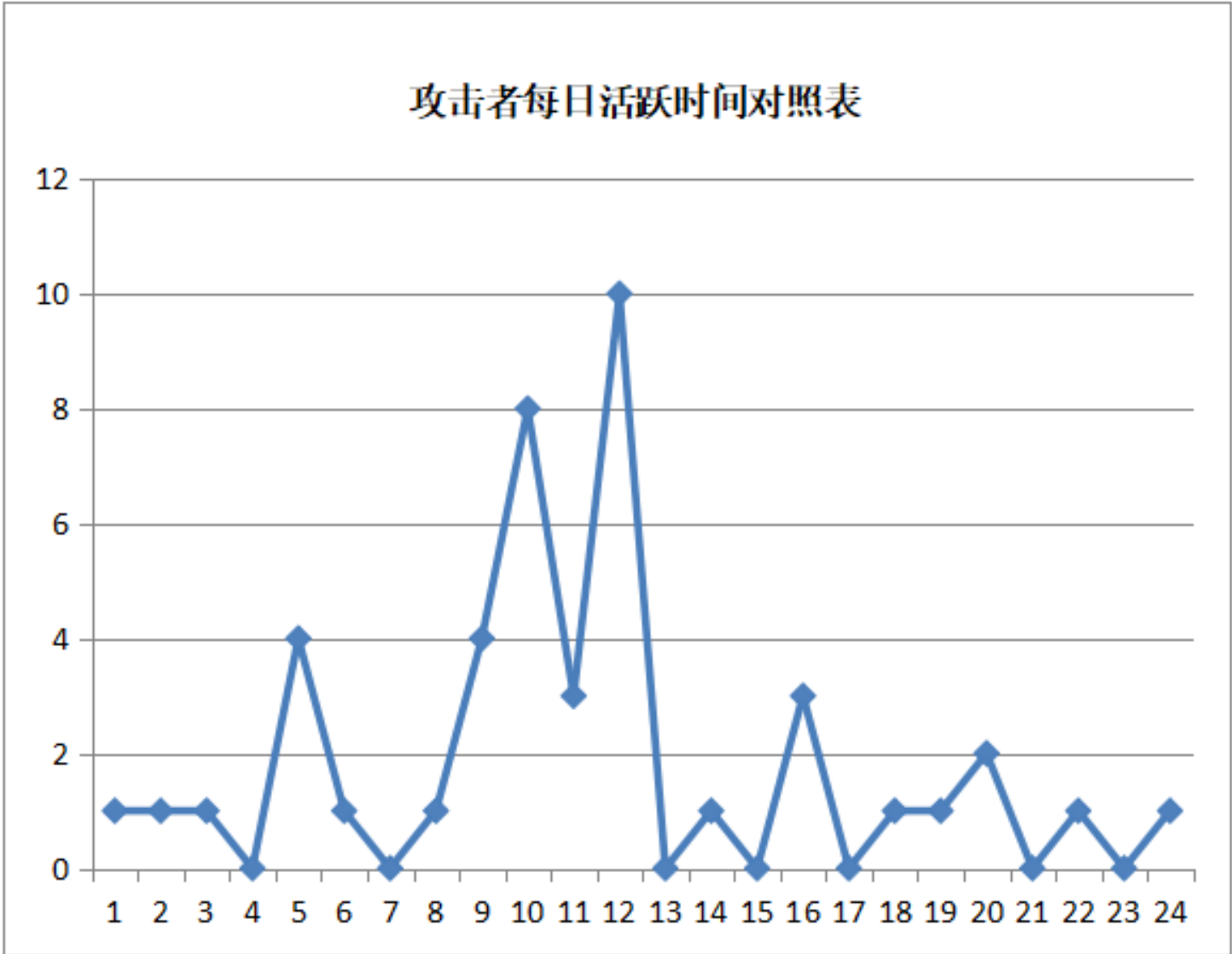


图4.3 攻击者24小时活跃分布图

总结

在分析中，我们也发现在其 XML 配置文件中遗留的feeds.rapidfeeds.com相关链接也曾卡斯基的相关报告中提及（见参考链接），也印证了摩诃草团伙在过去一直在更新其 C&C 配置的获取通道，并延续了其过去的解密算法和相关 C&C 链接特征。

此外，在网络战的角度，印巴冲突，因克什米尔的领土纠纷冲突数十载，包括此前南亚APT组织Donot、Bitter，使用克什米尔之音作为诱饵针对巴基斯坦发起攻击，南亚APT团伙TransparentTribe，使用恐怖袭击克什米尔为主题针对印度发起攻击，种种交手都证明了网军将会是网络战中，为捍卫国家主权，同时刺探军情的重要一环。

而印度试图废除印控克什米尔这一举措，无异于将引爆两国矛盾，截止本文发表日期，双方交火以至数名士兵死亡，而在网络攻击方面，攻击热度将会持续升温。而此前，南亚APT团伙摩诃草、Bitter、Donot曾多次针对中国发起攻击，且近期攻击仍有上升趋势，中方势必必要严加防守。

奇安信威胁情报中心势必为客户第一时间提供最新的攻击动向，协助政企抵御外敌网络入侵。目前奇安信旗下所有攻击检测类产品，包括天眼高级威胁检测系统、天擎终端安全管理平台、NGSOC/态势感知系统等，已经支持对相关威胁的检测和处置。

IOCs

C2:

139.28.38.236

AES密钥:

DD1876848203D9E10ABCEEC07282FF37

BlowFish密钥:

F0E1D2C3B4A5968778695A4B3C2D1E0F0011223344556677

主机名:

WIN-ABPA7FG820B

附录

提取到的C2信息

C2	时间	github用户名
http://149.56.80.64/u5b62ed973d963913bb/u5a3ewfasdk9.php	2018-07-03T05:19:43	y4seenkhan
http://149.56.80.64/u5b62ed973d963913bb/u5a3ewfasdk9.php	2018-07-03T05:29:54	hazkabeeb
http://43.249.37.165/kungfu/ghsnls.php	2018-07-04T12:45:13	Zunaid-zunaid1
http://123.57.158.115/shujing/ghsnls.php	2018-07-04T14:39:00	Zunaid-zunaid1
185.82.217.200/@lb3rt/dqvabs.php	2018-07-04T20:46:50	Zunaid-zunaid1
185.82.217.200/N3wt0n/dqvabs.php	2018-07-04T22:01:40	aleks0rg0v
http://185.82.217.200/d3m0n/dqvabs.php	2018-07-05T10:43:25	Vldir
http://81.17.30.28/th0mas/dqvabs.php	2018-07-05T20:30:57	Alaeck
http://46.183.216.222/0racl3/dqvabs.php	2018-07-07T12:10:04	yamichaeldavid
http://91.229.79.183/b15d0e30a7738037/j8fiandfuesmg.php	2018-07-10T16:26:55	habrew
http://176.107.182.24/f0357a3f154bc2ff/sadk9f043ejf.php	2018-07-10T16:35:49	ehsaankhan
http://146.185.234.71/Ms3f3g45thgy5/f3af3fasf32.php	2018-07-11T00:03:07	dawood
http://185.203.116.58/d394d142687ff5a0/dfae43rsfdgq4e.php	2018-07-11T01:24:49	fangflee
185.156.173.73	2018-07-11T02:47:04	noorhasima
http://188.165.124.30/c6afebaa8acd80e7/byuehf8af.php	2018-07-11T03:15:07	alfreednobeli
http://146.185.234.71/Ms3f3g45thgy5/f3af3fasf32.php	2018-07-11T09:27:55	jahilzubaine
94.156.35.204	2018-07-11T11:23:16	husngilgit
http://94.156.35.204/22af645d1859cb5c/sg4gasdnjf984.php	2018-07-11T16:26:29	raqsebalooch
185.203.118.115	2018-07-12T10:19:05	lctst
185.29.11.59	2018-07-13T18:28:04	rehmanlaskkr
?桔%口?崑`麟3	2018-07-13T19:33:56	noorfirdousi
185.206.144.67	2018-07-14T12:04:38	rizvirehman
185.36.188.14	2018-08-20T10:58:18	fakheragainfkhrr
199.168.138.119	2018-08-24T12:46:00	malikzafar786
199.168.138.119	2018-08-24T12:55:02	malikzafar786
199.168.138.119	2018-08-24T12:57:59	malikzafar786
85.217.171.138	2018-09-01T09:47:20	malikzafar786
85.217.171.138	2018-09-01T09:53:03	malikzafar786
http://46.183.216.222/0racl3/dqvabs.php	2018-09-01T10:35:34	malikzafar786
199.168.138.119	2018-09-18T10:34:23	malikzafar786
199.168.138.119	2018-09-18T10:37:49	malikzafar786
193.37.213.101	2018-11-05T11:53:40	a1amir1

2019/8/27奇安信威胁情报中心

178.33.94.35	2018-12-05T12:11:46	malikzafar786
178.33.94.35	2018-12-05T12:38:34	malikzafar786
;3癰??^a;?筛	2018-12-17T06:50:14	yusufk1
185.29.11.59	2019-01-15T08:03:17	str1ngstr
164.132.75.22	2019-03-01T05:28:04	z00min
193.22.98.17	2019-05-27T05:47:11	alexboycott
91.92.136.239	2019-06-24T11:14:16	imrankhan713
91.92.136.239	2019-06-24T12:05:21	imranikhan17
185.116.210.8	2019-07-18T10:35:43	chrisyoks
185.161.210.8	2019-07-18T12:10:48	johnhenery12
139.28.38.231	2019-08-07T10:58:56	petersonmike
139.28.38.236	2019-08-08T09:06:03	shaikmalik22

参考资料

1. <https://securelist.com/the-dropping-elephant-actor/75328/>

🔍 APT 摩诃草

分享到：

🏠 首页

摩诃草团伙利用公用平台分发C&C配置攻击活动揭露 >

